

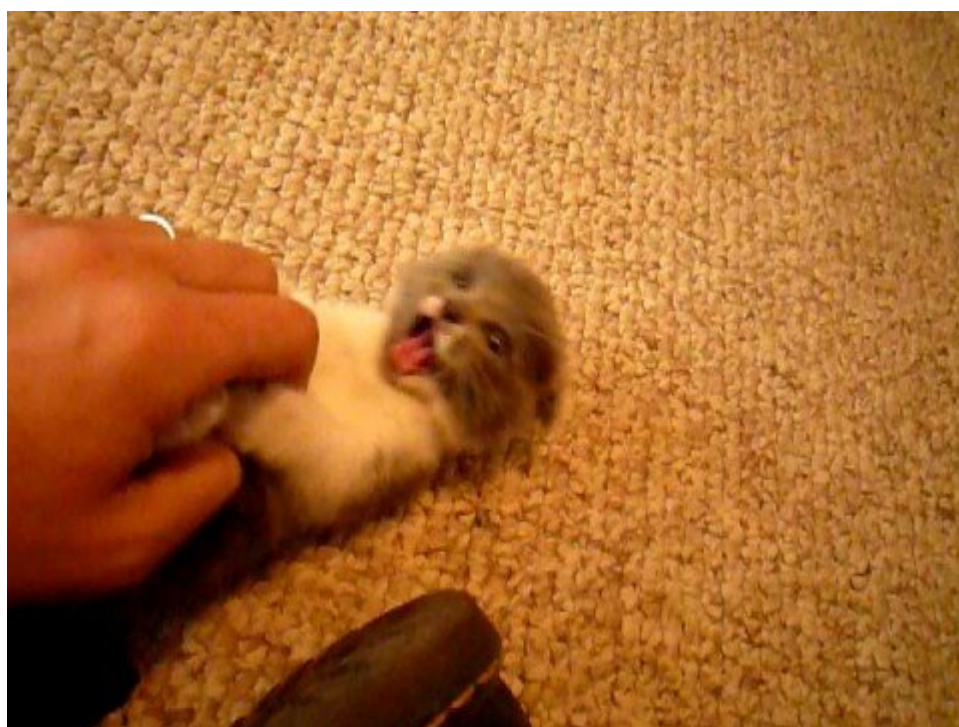
REPORT DE AUDITORÍA: ANÁLISIS DE VULNERABILIDADES

Autor: Xavier Margalef

Actividad: Actividad 01 & 02 - Priorización y Mitigación de Hallazgos (NIST NVD)

Fecha: 1 de julio de 2026

Actividad [AP 10] Vulnerabilidades Lab



Haz clic en la imagen superior para reproducir el video de la actividad. Si repudio.

Actividad 01 - Priorización de Vulnerabilidades (NIST NVD)

$$\text{Riesgo} = \text{Impacto} \times \text{Probabilidad}$$

1. Matriz de Priorización (De Mayor a Menor Gravedad)

Posición	CVE	CVSS v3.1	Vector (AV)	Tríada CIA	Criticidad	Factor de Riesgo / Hallazgos
1º	CVE-2019-9670	9.8	Red (Remoto)	C:H / I:H / A:H	 Crítica	En el KEV de CISA. Exploits en el mundo real.
2º	CVE-2019-9636	9.8	Red (Remoto)	C:H / I:H / A:H	 Crítica	Fallo en librería central. Sesgo por Python 2.
3º	CVE-2019-9638	7.5	Red (Remoto)	C:H / I:N / A:N	 Alta	Volcado de memoria vía metadatos EXIF.
4º	CVE-2019-9637	7.5	Red (Remoto)	C:H / I:N / A:N	 Alta	Condición de carrera en función <code>rename()</code> .

2. Justificación Técnica y Dependencias de Activos

Bloque Crítico (Score 9.8)

Son los más peligrosos: entran por red (**AV:N**), la complejidad es baja (**AC:L**), y van sin privilegios (**PR:N**) ni interacción del usuario (**UI:N**). Te rompen el perímetro de forma automatizada (**Zero-Click** (que luego según MITRE vendría 1-Click y luego Multi-Click)).

- 1º - **CVE-2019-9670 (Zimbra)**

Inyección XXE (ataque que aprovecha parsers XML inseguros para leer archivos locales) en el componente `<code>mailboxd</code>` de Zimbra (plataforma de correo colaborativa corporativa).

 **Impacto en Activos:** Impacta much la tríada completa ($V_{\text{activo}} = \max(C : 10, I : 10, A : 10) = 10$). Esta en el primer puesto porque está en el catálogo **KEV de CISA** (agencia de ciberseguridad de EE.UU.). Hay actores APT usándola activamente en producción. El impacto de negocio aquí es crítico porque te tumba el correo corporativo directamente.

- **2º - CVE-2019-9636 (Python)**

Fallo de codificación Unicode durante la normalización NFKC en las funciones

`<kbd>urlsplit</kbd>` y `<kbd>urlparse</kbd>` de `<kbd>urllib</kbd>` (módulo nativo de Python para manejar URLs). Permite meter URLs manipuladas para redirigir credenciales, llaves o cookies a un servidor externo.

⚠ **Impacto en Activos:** El daño técnico es igual al de Zimbra, pero al ser una librería base, necesitas que una app de terceros la implemente mal para habilitar el vector. Además, afecta a sistemas viejos con **Python 2** (versión obsoleta sin soporte); como hoy en día Python 3 es el estándar, la superficie de ataque real se reduce bastante y por eso se queda un paso por detrás.

● Bloque Alto (Score 7.5)

Bugs en componentes internos de PHP (lenguaje backend para desarrollo web). Son remotos y sin interacción, pero el impacto técnico inicial se frena exclusivamente en la **Confidencialidad**, dejando intactas la Integridad y la Disponibilidad.

- **3º - CVE-2019-9638 (PHP EXIF)**

Fuga de memoria no inicializada en la función `<kbd>exif_process_IFD_in_MAKERNOTE</kbd>` del componente EXIF de PHP (módulo que procesa metadatos de cámaras en imágenes JPG).

⚠ **Impacto en Activos:** Genera una **dependencia transitiva** peligrosa (un fallo en cascada donde un componente secundario compromete a la app principal). El volcado de memoria aleatorio puede escupir tokens de sesión o credenciales de otras aplicaciones del sistema, sirviendo de palanca para saltar a activos más críticos.

- **4º - CVE-2019-9637 (PHP `rename()`)**

Fallo de permisos al mover archivos entre sistemas de ficheros distintos, dejando el archivo temporalmente abierto a todo el mundo (`world-readable`).

⚠ **Impacto en Activos:** Rompe la Confidencialidad, pero cierra la lista porque para explotarlo dependes de una condición de carrera (**Race Condition**: bug que requiere ejecutar una acción en una fracción de segundo exacta antes de que otra termine). La ventana de tiempo para cazar el archivo es milimétrica, lo que tumba la probabilidad real del hallazgo.

Actividad 02 - Análisis de Incidentes Reales y Explotación de Vulnerabilidades

1. Matriz de Relación: Vulnerabilidad, CVE e Incidente Real

Componente Afectado	CVE Asociado	Incidente Real / Empresa Afectada	Tipo de Impacto Técnico	Criticidad NVD
Apache Struts	CVE-2017-5638	Equifax (2017)	Ejecución Remota de Código (RCE)	● Crítica (10.0)
Librería de compresión (zlib)	CVE-2022-37434	Sistemas Linux / Servidores Críticos	Desbordamiento de Búfer (Buffer Overflow)	● Crítica (9.8)
Sistema de gestión de BBDD	CVE-2012-2122	Servidores de Production Globales (MySQL)	Bypass de Autenticación (Auth Bypass)	● Alta (7.5)

2. Investigación Técnica de los Ataques

🛡️ Hallazgo 1: Apache Struts — El caso Equifax

- **Cómo se llevó a cabo el ataque:** El fallo estaba en el framework **Apache Struts** (entorno de desarrollo Java para aplicaciones web empresariales) y afectaba concretamente a **Jakarta** (el componente parser encargado de procesar la subida de archivos). Los atacantes descubrieron que inyectando código malicioso en la cabecera HTTP `<Content-Type>`, el parser se bugeaba al lanzar un mensaje de error y ejecutaba los comandos directamente en el sistema operativo del servidor. En el caso de **Equifax** (agencia global de informes de crédito financiero en EE.UU.), los atacantes explotaron este RCE para colarse en su servidor web expuesto, escanear la red interna y moverse lateralmente hacia las bases de datos de producción que tenían segmentadas por detrás.

🇪🇺 **Impacto en Activos:** Quiebra total de **Confidencialidad** e **Integridad** ($C : H/I : H/A : H$). Los atacantes camparon a sus anchas durante meses exfiltrando datos financieros críticos de 147 millones de clientes. A nivel de negocio, supuso un impacto financiero brutal en multas regulatorias, costes de respuesta ante incidentes, auditorías forzadas de cumplimiento y un golpe reputacional histórico.

- **Mitigación Operativa:**

1. *Parcheado:* Actualización inmediata de Apache Struts a las versiones estables libres del bug ([2.3.32](#) o [2.5.10.1](#)).
2. *Workaround:* Deshabilitar o cambiar el plugin de Jakarta por otro parser de subidas (como el de Pell) o meter reglas específicas en el WAF para tumbar cualquier petición HTTP con cabeceras sospechosas.

Hallazgo 2: Librería de compresión de datos (zlib)

- **Cómo se llevó a cabo el ataque:** Ocurre un desbordamiento de búfer (*heap-based buffer overflow*: corrupción de memoria dinámica en la RAM) en la función `inflateBacksmith` al procesar metadatos de archivos comprimidos en formato `gzip`. Un atacante podía construir un archivo comprimido malicioso con un campo de texto extra (`extra field`) extremadamente largo en su cabecera. Cuando cualquier daemon de red o servicio crítico en Linux que usara la librería **zlib** (librería core de compresión/descompresión estándar por defecto en Linux) intentaba procesar ese archivo, la función asignaba menos memoria de la necesaria en el heap (montículo es el área de memoria dinámica que utilizan los programas para almacenar datos cuyo tamaño o ciclo de vida no se conoce de antemano). El texto largo desbordaba el búfer asignado, corrompiendo los punteros de memoria adyacentes y permitiendo ejecutar un payload para tomar el control del servidor.

 **Impacto en Activos:** Quiebra total de la Tríada CIA ($C : H/I : H/A : H$). Al ser **zlib** un componente central del sistema operativo del que dependen cientos de aplicaciones y binarios de infraestructura, este hallazgo genera una **dependencia transitiva** masiva. Si el servicio de descompresión corre con altos privilegios, el atacante compromete la disponibilidad del servidor o escala privilegios hasta hacerse root.

- **Mitigación Operativa:**
 1. *Saneamiento:* Actualizar la librería de compresión **zlib** a la versión **1.2.13** o superior mediante el gestor de paquetes de la distribución (`apt-get upgrade zlib1g` o `yum update zlib`).
 2. *Compilación:* En sistemas cerrados o firmwares aislados, recompilar el software vinculando estáticamente la nueva versión de zlib y activando protecciones a nivel de compilador como **ASLR** y **Stack Canaries**.

Hallazgo 3: Sistema de gestión de BBDD (MySQL/MariaDB)

- **Cómo se llevó a cabo el ataque:** Un error de fundido de tipos (*type casting*: una mala conversión matemática entre tipos de datos en el código) en el proceso de verificación del hash del password permitía saltarse por completo la autenticación. El motor de **MySQL** (sistema de gestión de bases de datos relacionales de código abierto) comparaba el token de seguridad usando una función que, debido al fallo, tenía una probabilidad de 1 entre 256 de devolver un valor verdadero (`true`) aunque la contraseña metida fuera falsa. Si un atacante lanzaba un ataque de fuerza bruta rápido automatizando unas 300 peticiones de login seguidas con el usuario `root` y contraseñas de relleno, por pura estadística el servidor validaba una de las conexiones y le abría una sesión con privilegios de administrador.

 **Impacto en Activos:** Quiebra total de la **Confidencialidad** y la **Integridad** de los datos ($C : H/I : H/A : N$). El impacto directo fue la exposición de servidores de bases de datos de producción globales que estaban mal configurados y conectados a internet, permitiendo a los atacantes exfiltrar tablas enteras, borrar registros y dumper información masiva de clientes sin credenciales válidas.

- **Mitigación Operativa:**

1. *Solución Directa:* Actualizar el motor de base de datos a las versiones parcheadas de seguridad oficiales de MySQL (posteriores a **5.1.63** y **5.5.24**).
2. *Hardening de Red:* Aplicar aislamiento perimetral cerrando el puerto por defecto **3306** al tráfico externo de internet. La base de datos solo debe escuchar peticiones en la interfaz local (**localhost**) del backend o ser accesible mediante túneles de VPN autorizados.